NETWORK SECURITY / GCP / PCI-INFORMED REFERENCE DESIGN

Bidirectional public peering

An isolated blockchain DMZ. One private, inspected application boundary. No direct internet-to-CDE path.

OPTION A / REV 2 / PROPOSED

28 OCT 2026

PUBLIC P2P POLICY
Peers and nodes may initiate

INSPECTABLE TLS
Private RPC only — two TLS legs

DATA BOUNDARY
No PAN / SAD in blockchain flows

01
Public internet
Untrusted peers

Public peers
Ethereum + Base public test networks

Dynamic peer IPs

P2P: NATIVE TCP / UDP

No standard TLS interception. No HTTP WAF coverage.

02
Security edge
Dedicated perimeter controls

Cloud Armor network
Advanced DDoS on edge VIPs [1]

C1 / PALO ALTO / STATEFUL L4

Perimeter NGFW
Node-specific VIPs + DNAT

Approved peer egress + SNAT

Exact listeners; symmetric state

SESSION INITIATION

Teal: public peer → node. Blue: node → public peer. Both exchange data in either direction.

GAP: opaque P2P has no payload DLP. Private RPC inspection does not close this exfil path. [2]

03
Blockchain DMZ
Separate VPC / isolated node tier

C4 / ISOLATED HOSTS / NO PUBLIC VM IPs

Self-hosted nodes

Ethereum Sepolia
Geth + Lighthouse

Base Sepolia
Reth + rollup node

Private Base → Ethereum APIs [3]

Host-local RPC
Never public

NODE-LOCAL PROXY / SIDECAR

Private node TLS endpoint
Accept only the private policy tier.

Forward to local RPC; restrict methods.

Engine API / admin / metrics stay private.

TLS B: policy tier → node endpoint

04
Private boundary
Palo TLS + RPC policy controls

C1 / SEGMENTATION / DEFAULT DENY

Boundary policy
Only named RPC callers.

No public reachability to CDE.

No new node → CDE sessions.

No direct RPC bypass route.

Exact node dependencies are separately allowlisted.

C2 + C3 / TLS INSPECTION HERE

Palo + RPC policy tier
Palo: TLS decrypt / IPS / re-encrypt.

RPC gateway: caller / method ACL.

Validate certificates on both legs.

Fail closed; no raw RPC bypass.

Responses use the same boundary.

05
Trusted workload
CDE or connected / in-scope tier

C5 / DATA + INTEGRITY BOUNDARY

Application isolation
No internet-facing node here.

No node-held payment keys.

No raw PAN / SAD in RPC, logs, contracts or chain data.

DMZ placement does not automatically remove PCI scope.

INITIATES PRIVATE HTTPS / 443

Internal application
Approved workload identity.

Validates RPC responses.

Signing keys isolated from nodes.

TLS A: app → policy tier

01 / PACKET CONTRACT

Ethereum listeners
Geth TCP/UDP 30303; Lighthouse TCP/UDP 9000 + UDP 9001.

Base listeners
TCP/UDP 9222 + 30303; validate configured versions. [3]

Peer egress
Approve separately; remote ports may differ from listeners.

02 / OPERATING CONTROLS

Controlled support
MFA-admin via separate private path; approved DNS / time / updates.

C6 / Evidence + detection
FW / IPS / RPC / EDR logs → SIEM; monitor peer and resource limits.

C4 / Host containment
EDR + patching; minimal IAM; no payment keys or sensitive business data.

03 / DESIGN ACCEPTANCE

Edge implementation
Cloud Armor Enterprise + regional DDoS enablement on supported edge VIPs. [1]

Enforcement evidence
Validate per-node DNAT, HA / return symmetry and no alternate route around NGFW.

PCI scope
Connected / security-impacting components may remain in scope. [4]

Solid arrows = session initiator. Dashed packet arrows = stateful replies. Short dashed vertical line = protection association.

Logical reference design, not deployed topology or PCI attestation. TLS inspection is the requested design choice, not a universal PCI mandate.

Controls C1–C6 map to the companion risk register. Sources [1]–[4] and design assumptions are in the README.

NETWORK SECURITY / GCP / PCI-INFORMED REFERENCE DESIGN

Outbound-only peering

An isolated blockchain DMZ. One private, inspected application boundary. No direct internet-to-CDE path.

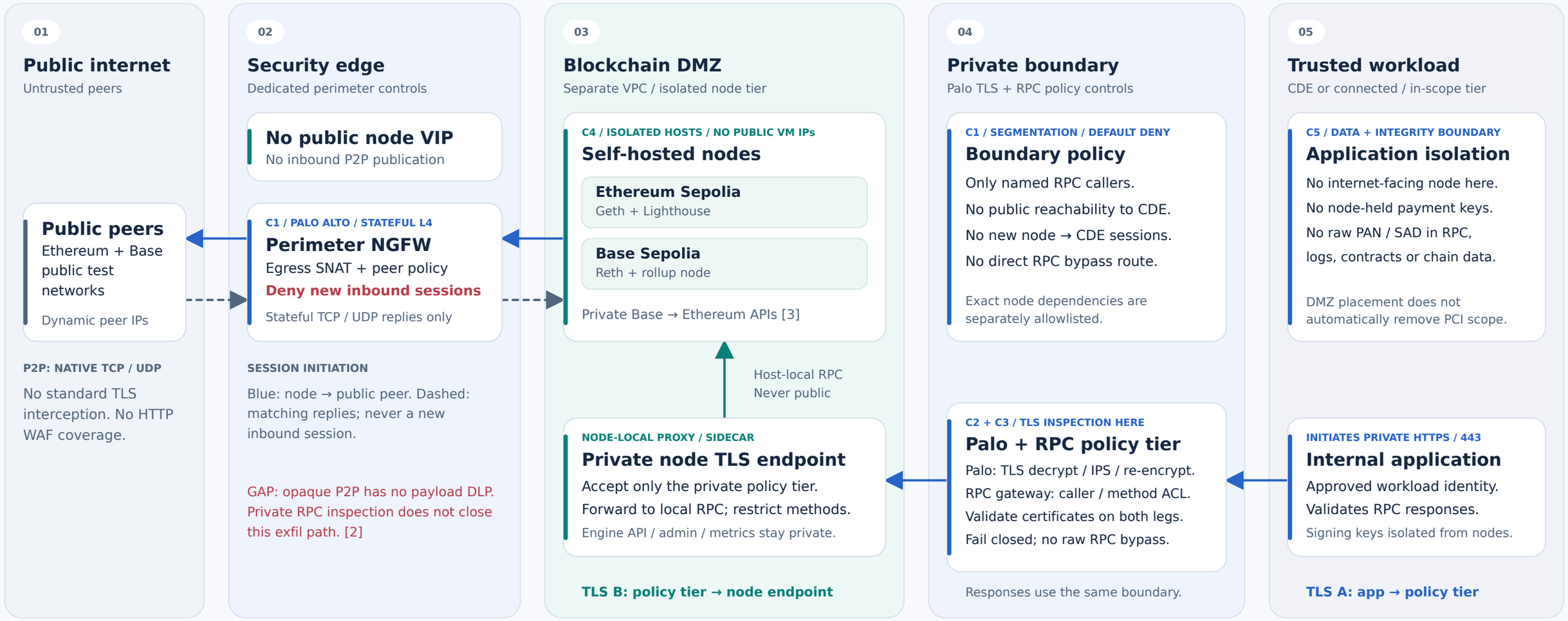
OPTION B / REV 2 / PROPOSED

28 OCT 2026

PUBLIC P2P POLICY
Node initiates only; replies allowed

INSPECTABLE TLS
Private RPC only — two TLS legs

DATA BOUNDARY
No PAN / SAD in blockchain flows



01 / PACKET CONTRACT

Internet ingress
Deny new sessions. No public node VIP / DNAT.

Peer egress
Approve actual discovery / peer destinations and ports.

State tracking
Replies only; no broad inbound ephemeral-port rule.

02 / OPERATING CONTROLS

Controlled support
MFA-admin via separate private path; approved DNS / time / updates.

C6 / Evidence + detection
FW / IPS / RPC / EDR logs → SIEM; monitor peer and resource limits.

C4 / Host containment
EDR + patching; minimal IAM; no payment keys or sensitive business data.

03 / DESIGN ACCEPTANCE

Client feasibility — not yet proven
Verify Base outbound-only support, cold sync, steady sync and peer-loss recovery.

Enforcement evidence
Test segmentation, fail-closed inspection and symmetric SNAT return paths.

PCI scope
Connected / security-impacting components may remain in scope. [4]

Solid arrows = session initiator. Dashed packet arrows = stateful replies. Short dashed vertical line = protection association.

Logical reference design, not deployed topology or PCI attestation. TLS inspection is the requested design choice, not a universal PCI mandate.

Controls C1–C6 map to the companion risk register. Sources [1]–[4] and design assumptions are in the README.

NETWORK SECURITY / BLOCKCHAIN DMZ / REVISION 2

ALL ITEMS OPEN / NOT VALIDATED

Risk register & control coverage

Eight risks. Explicit control limits. Applies to the two proposed DMZ diagrams—not an implementation attestation.

KEY LIMIT

Private-leg TLS inspection does not provide public-P2P payload DLP or prove that RPC responses are truthful.

ID	RISK / APPLICABILITY	WHAT THE CONTROLS COVER	WHAT REMAINS EXPOSED	PROPOSED OWNER / STATE
R1	**Node process / host takeover** A + B · C1, C4, C6	L4 limits exposed services; patching, hardened hosts and EDR reduce or detect compromise. SIEM supports response.	No decrypted P2P exploit coverage is credited. Malicious input still reaches the client over allowed sessions; EDR can miss it.	**Endpoint + SecOps** NetSec supports **Partial / open**
R2	**Exfiltration over allowed P2P** A + B · C1, C3, C4, C5	Keep sensitive inputs, signing keys and broad credentials off nodes. Narrow RPC data contract and IAM limit what can be read.	No guaranteed content-based prevention on opaque public P2P. Data readable by a compromised node may leave; outbound-only does not fix it.	**Project risk owner** App + Cloud + NetSec **Material gap / open**
R3	**Pivot into CDE or cloud services** A + B · C1, C2, C4	Separate VPC, node-level rules and segmentation deny new node-to-workload sessions. Minimal cloud identity limits API access.	Permitted RPC responses and explicit dependencies remain attack paths. Cloud IAM exposure must be tested, not inferred from IP isolation.	**NetSec + Cloud IAM** App validates replies **Partial / open**
R4	**RPC abuse or sensitive requests** A + B · C2, C3, C5	Private Palo decrypts / IPS / re-encrypts. Separate RPC gateway authenticates callers, restricts methods and validates inputs / resource use.	TLS inspection is not business-data authorization. Generic IPS is not JSON-RPC DLP. Allowed inputs are visible to the node.	**App / API platform** NetSec owns Palo **Partial / open**
R5	**False RPC results / peer isolation** A + B · C4, C5, C6	Secure transport and monitoring protect the path. Application validation and independent verification are needed for material decisions.	A compromised node can lie without changing the blockchain. TLS / IPS cannot certify chain truth; independent checks are not yet specified.	**Application owner** Blockchain engineers **Not resolved by NSCs**
R6	**DDoS, resource exhaustion, outage** A + B · C1, C3, C4, C6	A: Cloud Armor advanced network DDoS protects supported edge IPs. Both: connection / peer / RPC limits, capacity alerts and recovery controls.	Network DDoS protection does not stop every valid-but-expensive peer request. B removes public listeners, not peer-driven exhaustion.	**NetSec + Platform** SecOps monitors **Partial / open**
R7	**Control bypass / unproven PCI scope** A + B · C1–C6	Default-deny paths, private endpoints, no bypass routes, fail-closed inspection and centralized evidence support segmentation testing.	Misrouting, public IPv6, TLS exclusions or broad rules can bypass controls. DMZ is not automatically out of PCI scope.	**NetSec + PCI owner** Platform implements **Evidence pending**
R8	**Unworkable client / NAT assumptions** A + B · C1, C6	A: prove per-node publication, NAT symmetry and failover. B: prove cold sync, steady sync and peer-loss recovery for the exact stack.	No deployment tests performed. Base outbound-only support and exact Cloud Armor / appliance / HA placement remain unverified.	**Blockchain + Platform** NetSec validates path **Feasibility pending**

C1 Perimeter / segmentation C2 Private Palo TLS + IPS C3 RPC identity / method / data policy

C4 Endpoint / patching / IAM C5 Data minimization / result validation C6 DDoS / SIEM / evidence

Recommended starting point: B if the exact stack passes feasibility tests; otherwise A requires a justified public-listener exception.

Role owners are proposed, not assigned. No likelihood scores or residual-risk acceptance are invented; project facts and test evidence are still needed.

28 OCT 2026 · Revised diagrams + source links in README · Risk acceptance belongs to the accountable project / business owner.